

Threat Analysis Report - KipuBankV3

Author: Everton Rocha

Date: 10/11/2025

1. Protocol Overview

KipuBankV3 is a smart contract that implements deposit, withdrawal, and individual balance management logic within a decentralized banking system. It stores user tokens, enables internal transfers, and provides administrative control through pause functions and full withdrawals by the owner.

The architecture is straightforward and follows standard security practices such as **ReentrancyGuard** and **pausability**.

2. Protocol Maturity Assessment

The protocol demonstrates an intermediate level of maturity it follows good design principles but lacks automated testing and formal documentation. It also lacks invariant validations and economic attack simulations.

The **owner** currently holds full control over the contract, which introduces a centralization and governance risk.

3. Attack Vectors and Threat Model

- **Business logic errors:** balance verification flaws may allow unauthorized withdrawals.
- **Administrative abuse:** the owner can drain all funds at any time.
- **Economic manipulation:** possible intermediate balance manipulation or race conditions.
- **Pause control risk:** loss of the owner key could permanently lock the contract.

4. Invariant Specification

INV-1: `sum(balances) == address(this).balance` → ensures accounting integrity.

INV-2: `balances[user] >= 0` → prevents state corruption.

INV-3: `owner != address(0)` → maintains valid administrative control.

INV-4: when `paused == true`, all financial operations must be blocked.

5. Impact of Invariant Violations

Breaking these invariants can lead to **direct fund loss, internal data corruption, or irreversible system failure**.

Such violations indicate critical weaknesses that must be mitigated through **property-based testing** and **independent audits**.

6. Recommendations

- Implement a **comprehensive test suite** using **Foundry** or **Hardhat**.
- Validate invariants using **Echidna** (property-based testing).
- Replace the single **owner** with a **multi-signature wallet** (e.g., Gnosis Safe).
- Submit the contract for **external auditing** before mainnet deployment.
- Emit **on-chain events** for all critical administrative and financial actions.

Conclusion

KipuBankV3 presents a solid architectural foundation but still lacks formal security validation and comprehensive testing.

By implementing the recommendations outlined above, the protocol can achieve a higher level of **trust, transparency, and operational resilience**, significantly reducing risks of **exploitation or governance failure**.